

Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ
ИТМО
ITMO University

Лабораторная работа №6

По дисциплине Информационная безопасность

Тема работы Политика ИБ

Обучающийся Сакулин Иван Михайлович

Факультет Факультет прикладной информатики

Группа К3321

Направление подготовки 11.03.02 Инфокоммуникационные технологии и
системы связи

Образовательная программа Программирование в инфокоммуникацион-
ных системах

Обучающийся

(дата)

(подпись)

Сакулин И.М.

(Ф.И.О.)

Руководитель

(дата)

(подпись)

Пикуль А.С.

(Ф.И.О.)

СОДЕРЖАНИЕ

Стр.

ВВЕДЕНИЕ	3
1 ОПИСАНИЕ ОРГАНИЗАЦИИ И ПРАВОВОЙ КОНТЕКСТ .	4
2 ПОЛИТИКА ИБ	5
2.1 Общие положения	5
2.2 Классификация защищаемой информации	5
2.3 Роли и ответственность	6
2.4 Базовые правила ИБ	7
2.5 Реагирование на инциденты	8
2.6 Ответственность и пересмотр политики	9
ЗАКЛЮЧЕНИЕ	10

ВВЕДЕНИЕ

Цель работы — разработать политику информационной безопасности для выбранной организации с учётом особенностей её деятельности, используемых информационных систем, обрабатываемых данных и применимых требований законодательства Российской Федерации.

Задачи:

- 1) охарактеризовать организацию, её информационные системы и обрабатываемые категории информации;
- 2) определить применимые к организации нормативные правовые акты и уровень защищённости персональных данных;
- 3) определить основные объекты и требования к защите информации в организации;
- 4) разработать основные положения политики информационной безопасности, включая распределение ответственности и базовые правила защиты информации;
- 5) определить порядок реагирования на инциденты информационной безопасности и ответственность за нарушение требований политики.

1 ОПИСАНИЕ ОРГАНИЗАЦИИ И ПРАВОВОЙ КОНТЕКСТ

Для работы возьму вымышленную организацию, придуманную на основе условной группы электромонтажников и дополненную менеджерской частью и ИТ-инфраструктурой.

ООО «Устье-Электрик» — небольшая коммерческая организация, осуществляющая монтаж и ремонт электрических сетей и оборудования в квартирах, частных домах и постройках. Деятельность осуществляется в пределах трёх муниципальных районов с суммарной численностью не более 100 тысяч человек. Штат организации около 10 человек, среди них: директор (бухгалтер), менеджер по работе с клиентами, ИТ-администратор, прораб и 6 электромонтажников.

Основные информационные системы и средства обработки информации: компьютеры и ноутбуки сотрудников, локальная сеть с выходом в Интернет, сайт и CRM на сервере (IaaS), файловое хранилище, бухгалтерская система и корпоративная почта (SaaS), а также рабочие телефоны и мессенджеры.

Организация обрабатывает персональные данные клиентов (ФИО, телефоны, адреса объектов, сведения о заказах и договорах) и работников (ФИО, контактные, паспортные и кадровые сведения), а также договорную, финансовую и техническую информацию.

К организации применимы следующие нормативные правовые акты.

152-ФЗ «О персональных данных» — обработка ПДн клиентов и работников. **149-ФЗ «Об информации, информационных технологиях и о защите информации»** — защита информации и используемых информационных систем. **ПП РФ от 01.11.2012 № 1119** — требования к защите ПДн и определение уровня их защищённости. **Приказ ФСТЭК России от 18.02.2013 № 21** — организационные и технические меры защиты ПДн. **98-ФЗ «О коммерческой тайне», ст. 10 ч. 1 и ст. 11 ч. 1** — защита коммерчески значимой внутренней информации.

В соответствии с п.12 ПП РФ от 01.11.2012 №1119 для информационной системы организации устанавливается 4-й уровень защищённости ПДн (УЗ-4), поскольку организация обрабатывает иные категории ПДн менее чем 100 000 субъектов при актуальности угроз 3-го типа.

2 ПОЛИТИКА ИБ

2.1 Общие положения

Настоящая политика устанавливает требования к защите информации в ООО «Устье-Электрик» и распространяется на работников и подрядчиков при наличии у них доступа к информационным системам или данным организации. Требование о принятии правовых, организационных и технических мер соответствует ст. 19 ч. 1 152-ФЗ и ст. 16 ч. 1 149-ФЗ.

Цель политики — обеспечение конфиденциальности, целостности и доступности персональных данных (ПДн), договорной, финансовой и технической информации. Требования применяются к рабочим компьютерам и ноутбукам, локальной сети, сайту и CRM, файловому хранилищу, бухгалтерской системе, корпоративной почте, рабочим телефонам и мессенджерам (ст. 19 ч. 1 152-ФЗ).

Основные термины политики:

- **ПДн** — персональные данные, относящиеся к прямо или косвенно определённому физическому лицу;
- **ИСПДн** — информационная система, в которой осуществляется обработка персональных данных;
- **учётная запись** — набор идентификационных данных, используемый для доступа сотрудника к информационной системе;
- **МФА** — многофакторная аутентификация пользователя с применением двух и более факторов подтверждения личности;
- **инцидент ИБ** — событие, которое привело или может привести к нарушению конфиденциальности, целостности или доступности защищаемой информации;
- **резервная копия** — копия данных, предназначенная для восстановления информации после её утраты или повреждения.

2.2 Классификация защищаемой информации

В организации выделяются три категории информации:

- 1) **Общедоступная** — название, услуги, общие контакты и информация, размещённая на сайте.
- 2) **Внутренняя** — инструкции, графики и служебная информация.
- 3) **Конфиденциальная** — ПДн клиентов и работников, договоры, финансовые документы, сведения о поставщиках, закупочных ценах и техническая документация.

Доступ к конфиденциальной информации предоставляется только в объёме, необходимом для выполнения должностных обязанностей. Передача подрядчикам допускается только при наличии основания и в пределах предоставленных полномочий (ст. 19 ч. 2 п. 8 152-ФЗ; для коммерческой тайны — ст. 10 ч. 1 пп. 2–4 98-ФЗ).

2.3 Роли и ответственность

Директор утверждает политику, организует обработку и защиту ПДн, определяет права доступа и принимает решения по существенным инцидентам. Является ответственным за организацию обработки ПДн (ст. 22.1 ч. 1, 4 пп. 1–3 152-ФЗ).

IT-администратор создаёт и блокирует учётные записи, назначает права доступа, контролирует обновления, организует резервное копирование и локализует инциденты в соответствии с мерами защиты ПДн (ИАФ.1, УПД, РСБ, ИНЦ Приказа ФСТЭК России № 21).

Работники используют только свои учётные записи, не передают пароли, соблюдают установленные права доступа, не передают ПДн без основания и сообщают об инцидентах IT-администратору или директору (бухгалтеру) (ст. 19 ч. 2 п. 8 152-ФЗ; ИАФ.1, УПД, РСБ, ИНЦ Приказа ФСТЭК России № 21).

2.4 Базовые правила ИБ

Доступ и учётные записи

Для каждого работника используется индивидуальная учётная запись; общие учётные записи не допускаются. Учётная запись увольняемого работника блокируется не позднее окончания его последнего рабочего дня. Проверка проводится по списку активных учётных записей (ИАФ.1, УПД Приказа ФСТЭК России № 21).

Работнику предоставляется минимально необходимый набор прав. Электромонтажники получают доступ только к данным, необходимым для выполнения заказов; бухгалтерские и кадровые данные доступны директору (бухгалтеру) и назначенным работникам (ст. 19 ч. 2 п. 8 152-ФЗ; УПД Приказа ФСТЭК России № 21).

Аутентификация и рабочие устройства

Пароли и средства аутентификации не передаются другим лицам и не хранятся в общедоступных местах. При наличии функции МФА она включается для администраторских учётных записей и удалённого доступа к корпоративным сервисам (ИАФ.1 Приказа ФСТЭК России № 21).

На рабочих компьютерах и ноутбуках устанавливается автоматическая блокировка экрана не более чем через 10 минут бездействия. Установка несвязанного с работой ПО без согласования с IT-администратором запрещается (внутренние проверяемые правила, реализующие управление доступом и ограничение программной среды: УПД, ОПС Приказа ФСТЭК России № 21).

Телефоны, почта и облачные сервисы

Рабочие телефоны должны иметь блокировку устройства. При утрате рабочего телефона сотрудник сообщает IT-администратору не позднее 1 часа с момента обнаружения утраты; доступ к корпоративным учётным записям

на устройстве блокируется (внутреннее правило реагирования; ст. 19 ч. 1 152-ФЗ; ИАФ, УПД, ИНЦ Приказа ФСТЭК России №21).

Перед отправкой документов проверяются адрес получателя и состав данных. Использование личной почты и личных облачных хранилищ для ПДн запрещается. Рабочие мессенджеры используются только для информации, необходимой для конкретного заказа, без передачи избыточных ПДн (ст. 19 ч. 1, ч. 2 п. 8 152-ФЗ; ст. 16 ч. 1 149-ФЗ).

CRM, файловое хранилище и другие SaaS-сервисы используются только через корпоративные учётные записи. Подрядчикам предоставляется минимально необходимый доступ на срок выполнения работ; после их завершения доступ блокируется (ст. 19 ч. 2 п. 8 152-ФЗ; для коммерческой тайны — ст. 10 ч. 1 пп. 2–4 98-ФЗ).

Резервное копирование

Резервному копированию подлежат данные CRM, договорные документы и бухгалтерской системы при наличии соответствующих функций. Автоматические резервные копии создаются не реже одного раза в сутки. IT-администратор не реже одного раза в квартал проверяет восстановление данных и фиксирует результат (ст. 19 ч. 2 п. 7 152-ФЗ; суточный интервал и квартальная проверка — внутренние проверяемые требования).

2.5 Реагирование на инциденты

К инцидентам относятся утрата рабочего устройства, отправка данных ненадлежащему получателю, вредоносное ПО, компрометация учётной записи, несанкционированный доступ к CRM или файлам, а также потеря или повреждение данных.

Работник прекращает действия, способствующие распространению инцидента, не удаляет связанные с ним сведения и сообщает IT-администратору или директору (бухгалтеру). При утрате устройства сообщение направляется

не позднее 1 часа (внутренний срок; ст. 19 ч. 2 п. 6 152-ФЗ; ИНЦ Приказа ФСТЭК России № 21).

IT-администратор фиксирует время и описание события, определяет затронутые системы и данные, при необходимости блокирует учётные записи или устройства, локализует инцидент и сохраняет сведения для анализа. При инциденте с ПДн информация передаётся директору (бухгалтеру) (ст. 19 ч. 2 п. 6 152-ФЗ; РСБ, ИНЦ Приказа ФСТЭК России № 21).

При неправомерной или случайной передаче, предоставлении, распространении либо доступе к ПДн, повлекших нарушение прав субъектов, организация выполняет требования ст. 21 ч. 3.1 152-ФЗ. Первичное уведомление направляется в уполномоченный орган в течение **24 часов**, а результаты внутреннего расследования — в течение **72 часов**.

Требования к обработке и защите ПДн подрядчиками закрепляются в договорах (ст. 19 ч. 1–2 152-ФЗ; при коммерческой тайне — ст. 10 ч. 1 п. 4 98-ФЗ).

2.6 Ответственность и пересмотр политики

За нарушение политики работники несут ответственность в соответствии с законодательством Российской Федерации и локальными актами организации. К нарушениям относятся передача учётных данных, предоставление лишнего доступа, использование личных облачных хранилищ для ПДн, несвоевременное сообщение об инциденте и установка неразрешённого ПО (ст. 18.1 ч. 1 п. 3–4 152-ФЗ; для коммерческой тайны — ст. 11 98-ФЗ).

Политика пересматривается не реже одного раза в год, а также при изменении законодательства, информационных систем или структуры организации либо после серьёзного инцидента. Ежегодный пересмотр является внутренним контрольным сроком; необходимость внутреннего контроля и актуализации мер следует из ст. 18.1 ч. 1 п. 3–4 152-ФЗ и ст. 19 ч. 2 п. 9 152-ФЗ. Изменения подготавливает ответственное лицо совместно с IT-администратором и утверждает директор.

ЗАКЛЮЧЕНИЕ

В ходе работы была разработана политика информационной безопасности для небольшой коммерческой организации ООО «Устье-Электрик» с учётом её организационной структуры, используемых информационных систем и обрабатываемых данных.

В политике определены категории защищаемой информации, распределены обязанности между директором, IT-администратором и работниками организации. Установлены базовые правила управления учётными записями, разграничения доступа, защиты рабочих устройств, использования мобильных устройств, облачных сервисов, электронной почты и резервного копирования.

Также определён порядок действий при возникновении инцидентов информационной безопасности и учтены установленные законодательством сроки уведомления об инцидентах, связанных с нарушением безопасности персональных данных.